

RBAC MATRIX

7 ROLES × CAPABILITIES

The authoritative role-to-capability map for Cedric Masters Autos, derived from the server-side requireRole guards, route-level guards, and navigation gating. Admin bypasses every check; a null role is denied everywhere.

DOCUMENT ID CMA-RBAC-001	ROLES 7	CAPABILITIES 41	DATE 07 Aug 2026
ENFORCEMENT Server-side	MODEL Default-deny	BYPASS Admin only	SOURCE commit 0a26911

01 MODEL OVERVIEW

■ • Full access ■ • Scoped access (assigned-own only) ■ • Unconditional override (Admin) □ — No access

MODEL isAuthorized(role, allowed): null → deny · admin → true · else membership.

ADMIN

Unconditional bypass; user mgmt, rates, everything.

CSR / ADVISOR

Front desk: check-in, customers, appointments, labour lines.

TECHNICIAN

Diagnose + work own jobs, request parts. No invoices, no customers.

INVENTORY MGR

Parts catalogue, stock, approve/dispatch/reverse requests.

FINANCE

Invoices, approval, payments, labour & VAT settings.

MANAGER

All service ops, completes jobs, approves invoices, oversees.

SALES REP

Leads, sales orders, deliveries, sales inventory exposure.

02 CAPABILITY MATRIX

Capability	Admin	CSR	Tech	Inv Mgr	Finance	Manager	Sales
Navigation & Read Access							
Dashboard	●	●	●	●	●	●	●
Customers (list/detail)	●	●	—	—	●	●	—
Jobs board (all)	●	●	●	●	●	●	—
Appointments	●	●	—	—	—	●	—
Customer vehicles (read)	●	●	—	—	—	●	—
Parts catalogue	●	—	—	●	—	●	—
Finance (invoices/settlements)	●	—	—	—	●	●	—
Sales pipeline (inv/leads/orders)	●	●	—	—	—	●	●
View job items & invoices	●	●	—	●	●	●	—
User management page	●	—	—	—	—	—	—
Service (After-Sales) — Writes							
Create / update customer	●	●	—	—	—	●	●
Create / update vehicle	●	●	—	●	—	●	●
Book / cancel / check-in appointment	●	●	—	—	—	●	—
Walk-in check-in (create job)	●	●	—	—	—	●	—
Assign technician	●	●	—	—	—	●	—
Record diagnosis	●	—	🔧	—	—	●	—
Start work	●	—	🔧	—	—	●	—
Mark ready for pickup	●	—	🔧	—	—	●	—
Complete job	●	—	—	—	—	●	—
Mark job paid	●	—	—	—	●	●	—
Add / remove labour item	●	●	—	—	●	●	—
Request parts (to waiting release)	●	—	🔧	—	—	—	—
Review parts request (approve/reject)	●	—	—	●	—	●	—
Dispatch / reverse parts	●	—	—	●	—	●	—
Finance & Configuration							
Generate / regenerate invoice	●	—	—	—	●	●	—
Approve invoice	●	—	—	—	●	●	—
Record service payment	●	—	—	—	●	●	—
Configure VAT & labour types	●	—	—	—	●	●	—

CAPABILITY	ADMIN	CSR	TECH	INV MGR	FINANCE	MANAGER	SALES
Create / edit / adjust sales vehicle	●	●	—	●	—	●	●
Create lead / change stage / follow-up	●	●	—	—	—	●	●
Create / complete / cancel sales order	●	●	—	—	—	●	●
Add sales-order payment	●	●	—	—	—	●	●
Delivery handover checklist	●	●	—	—	—	●	●
ADMINISTRATION							
List all users	●	—	—	—	—	—	—
Assign roles / activate & deactivate	●	—	—	—	—	—	—
Bootstrap first admin (one-time)	○	—	—	—	—	—	—

READING THIS MATRIX

● full · ● scoped to the user's own assigned jobs · ○ conditional (only succeeds while zero admins exist) · — denied.
 Admin is an **unconditional bypass** for every row; a user with no role is denied on every row (default-deny).

03

VERIFICATION

LAYER	ARTIFACT	COVERS
Server	convex/lib/auth.ts · src/lib/auth-utils.ts	requireRole, default-deny, admin bypass
Guards	convex/*.ts requireRole(...)	Per-mutation role whitelists in the matrix
UI gating	AppShell · route redirects	Nav visibility + unauth redirect per role
Tests	tests/convex/authz.test.ts	Anonymous rejection of users/customers/vehicles

AMPLIFY

The matrix should be locked by expanding tests/convex/authz.test.ts with per-role positive/negative cases (e.g., Technician cannot markPaid, Sales cannot checkIn) — these currently live only in manual walkthroughs.